Public Key Infrastructure(PKI)

Florence Love Nkosi, CISA| CEH

Problem with Digital signatures ??

Problem with Digital signatures

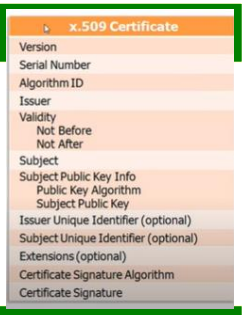
- There is a problem with how digital signatures are created and shared
- Anyone with Bobs public key can decrypt the message, hacker intercepts the message , they can get the message and decrypt the message, then modifies the message and puts it on a public message pretending to be Bob.
- Anyone can pretend to be bob, lack of authentication, it does not guarantee the authenticity of the user- Because public keys are shared in a public domain

Digital Certificates

- Digital certificates are electronic credentials issued by a trusted third party to verify the identity of the owner but also verifies that the owner, owns the public key.
- Digital certificates binds users to their public key
- Digital certificates are issued to computers, software packages or anything that need to prove their identity in the electronic world.
- A digital certificate, such as an SSL certificate, is a cryptographic file that binds a key pair to a validated entity.
- Digital certificates are based on the ITU standard X.509 which defines a standard certificate format for public key certificates and certification validation. Hence digital certificates are sometimes also referred to as X.509 certificates

Digital Certificates

- An digital certificate consists of the following components:
  - Version - The version of X.509 that is used.
  - Serial number - An integer that, together with the CA's name, uniquely identifies the certificate
  - Signature - The algorithm used to compute the signature on the certificate.



Digital Certificates

- The digital certificate will contain the following:
  - Issuer - The name of the issuing Certified Authority .
  - Validity - Contains two fields: the time that the certificate becomes valid, and the last time for which it is valid.
  - Subject - The name of the entity whose key is certified.
  - Subject Public KeyInfo - The subject's public key, along with the algorithm for which the subject's public
  - key is generated (e.g., RSA or DSA).
  - Algorithm Identifier - The algorithm used to compute the signature on the certificate. Contains the same
  - information as the Signature Field described above.
  - Encrypted - Contains the signature on all of the above Fields except Algorithm Identifier.

Example of a digital certificate



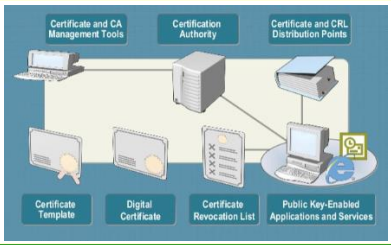
Public Key Infrastructure(PKI)

- PKI resolves this challenges (key distribution)by issuing and governing digital certificates that confirm the identity of people, devices or applications that own private keys and the corresponding public keys.
- In short, PKI assigns identities to public keys so that recipients can accurately verify the owners.
- Public Key Infrastructure is an infrastructure that uses digital certificates as an authentication mechanism and is designed to manage those certificates and their associated keys.
- This verification gives users confidence that if they send an encrypted message to that person (or device), the intended recipient is the one who will actually read it and not anyone else who may be sitting as a “man in the middle.”

Public Key Infrastructure

- A public key infrastructure (PKI) supports the distribution and identification of public encryption keys, enabling users and computers to both securely exchange data over networks such as the Internet and verify the identity of the other party.
- Public key infrastructure (PKI) governs the issuance of digital certificates to protect sensitive data, provide unique digital identities for users, devices and applications and secure end-to-end communications.
- Common examples of PKI security today are SSL certificates on websites so that site visitors know they're sending information to the intended recipient, digital signatures, and authentication for Internet of Things devices.

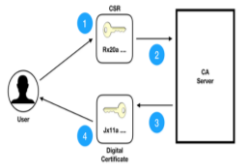
Components of PKI



Components of PKI

1. A **Certification Authority to issue certificates** – A trusted CA is the only entity that can issue trusted digital certificates. This is extremely important because while PKI manages more of the encryption side of these certificates, authentication is vital to understanding which entities own what keys. Without a trusted CA, anyone can issue their own keys, authentication goes out the window and chaos ensues.
2. **Policies that govern the PKI** – Bear in mind that PKI is largely about governance and management of digital CA certificates. I
   - In order to achieve both, a set of rules or guidelines must be in place to ensure things go smoothly. For larger commercial PKIs, they're determined by a collective of browsers and certificate authorities called the CA/B Forum.
3. T**he Digital Certificates themselves** – It's kind of tough manage a group of digital certificates that don't exist. In order for a PKI to work and exist properly, it needs to have digital certificates, otherwise—what's the point?
4. **Apps that are written to use the PKI** – This last one may seem abstract, it's really not. This just means any application that is PKI aware and uses the PKI to facilitate an encrypted connection. Take some of the larger commercial PKIs, this would mean web browser, email clients, etc

THE CERTIFICATION PROCESS



- In a PKI, a user applies for a digital certificate by first
- 1) sending a request CSR (Certificate Signing Request).
- The request is 2) sent to a CA (Certificate Authority) Server. The CA verifies the authenticity of the applicant, and if it is verified,
- the 3) CA issues a digital certificate. The applicant is now
- 4) authenticated by the CA server with a valid digital certificate which proves that the owner of the public key is the user.

PKI certificates

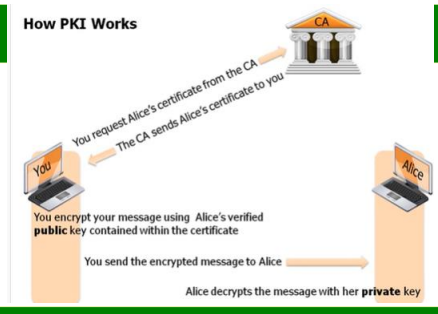
- PKI certificates are documents that act as digital passports, assigned to any entity that wants to participate in a PKI-secured conversation.
- One of the most important pieces of information a certificate includes is the entity's public key: the certificate is the mechanism by which that key is shared. But there's also the authentication piece.
- A certificate includes an attestation from a trusted source that the entity is who they claim to be.
- That trusted source is generally known as a **certificate authority (CA)**.

Certification Authorities (CAs)

- Certification Authorities (CAs) are responsible for issuing, revoking and distributing certificates.
- It is often a trusted third party organization such as: VeriSign, Symantec, DigiCert
- Stores the public key in a directory that is available to anyone that wants to verify your certificate.

Key Functions of CA

- The key functions of a CA are as follows −
  - **Generating key pairs** − The CA may generate a key pair independently or jointly with the client.
  - **Issuing digital certificates** − The CA could be thought of as the PKI equivalent of a passport agency − the CA issues a certificate after client provides the credentials to confirm his identity. The CA then signs the certificate to prevent modification of the details contained in the certificate.
  - **Publishing Certificates** − The CA need to publish certificates so that users can find them. There are two ways of achieving this. One is to publish certificates in the equivalent of an electronic telephone directory. The other is to send your certificate out to those people you think might need it by one means or another.
  - **Verifying Certificates** − The CA makes its public key available in environment to assist verification of his signature on clients' digital certificate.
  - **Revocation of Certificates** − At times, CA revokes the certificate issued due to some reason such as compromise of private key by user or loss of trust in the client. After revocation, CA maintains the list of all revoked certificate that is available to the environment.



Certificate Revocation List

- CA publishes a list of certificates that can no longer be used/ that have been revoked
- Certificate can be revoked because of:
  - Certificate expiration
  - Certificate revocation
    - Compromised Private key
    - Human resource- employee doesn't work for that organisation
    - Company changes name, physical address
  - Certificate suspended
  - Certificate owner/ administrator can request the certificate to be revoked.

Recovery Agent- When a key gets lost

- PKI allows for having a secure key recovery server
- Key recovery agent is a person who is authorized to recover key in certain cases
- Recovers keys that have been forgotten, i.e a users key was stored on a local computer that crashed.
- Sometimes there are two recovery Agents that are used to recover a single private key.

Key Storage

- The means of storing keys in a PKI system is important.
- Public keys can be stored by embedding them within digital certificates, while private keys can be stored on the user's local system.
- The drawback to software-based storage is that it may leave keys open to attacks: vulnerabilities in the client operating system, for example, can expose keys to attackers.
- Storing keys in hardware is an alternative to software-based storage.
- For storing public keys, special CA root and intermediate CA hardware devices can be used. Private keys can be stored on smart cards or in tokens.

Public Key Infrastructure benefits

1. **PKI authenticates you and your server.** It allows your site users' web browsers to authenticate your server before connecting with it (so they can verify that they're connecting to a legitimate server). You can also use client certificates to limit access to authenticated users. This gives you greater control over your network and other IT systems.
2. **PKI facilitates encryption and decryption.** PKI enables you to use digital certificates and public encryption key pairs to encrypt and decrypt data or the transmission channels you use to send it using the secure SSL/TLS protocol.
3. **PKI ensures the integrity of your data.** PKI lets users, their browsers or their devices know whether the data you send has been tampered with.

Where is PKI applied?

- Secure Browsing (via SSL/TLS)
- Securing Email (signing and encrypting messages)
- Secure Code-signing
- Network Security
- File Security (via Encrypted File Systems)

